

Web application security incident investigation

1. Scenario

Investigated a simulated web application compromise where an attacker gained administrative access through a brute-force attack against default credentials.

2. Responsibilities

- analyzed DNS and HTTP traffic using tcpdump
- Investigated malicious redirection behavior
- Identified unauthorized modifications to website source code
- Determined root cause of the compromise
- Documented incident findings and remediation recommendations

3. Key Findings

- administrative account was protected by default password
- Brute-force attack resulted in unauthorized administrative access
- Malicious JavaScript was embedded into website source code
- Users were redirected to a malicious domain hosting malware
- Customer devices were potentially compromised after executing downloaded files

4. Recommended controls

- multi-factor authentication (MFA)
- Password policy enforcement
- Account lockout controls
- Secure credential management
- Continuous monitoring of administrative accounts
- Source code integrity monitoring

5. Skills demonstrated

- incident analysis
- Root cause analysis
- Access control review
- Risk assessment
- Security documentation
- Network traffic analysis
- Remediation planning